High-Confidence Computing 5 (2025) 100240

Contents lists available at ScienceDirect

High-Confidence Computing

journal homepage: www.sciencedirect.com/journal/high-confidence-computing

Research Article

EBIAS: ECC-enabled blockchain-based identity authentication scheme for IoT device

Wenyue Wang [a], Biwei Yan [b], Baobao Chai [c], Ruiyao Shen [a], Anming Dong [d,e,*], Jiguo Yu [f]

[a] School of Computer Science, Qufu Normal University, Rizhao 276827, China
[b] School of Computer Science and Technology, Shandong University, Qingdao 266237, China
[c] School of Computer Science and Engineering, Shandong University of Science and Technology, Qingdao 266071, China
[d] Key Laboratory of Computing Power Network and Information Security Ministry of Education, Shandong Computer Science Center, Qilu University of Technology (Shandong Academy of Sciences), Jinan 250013, China
[e] Shandong Provincial Key Laboratory of Computer Networks, Shandong Fundamental Research Center for Computer Science, Jinan 250022, China
[f] Big Data Institute, Qilu University of Technology, Jinan 250013, China

ARTICLE INFO

Article history:
Received 14 December 2023
Revised 26 January 2024
Accepted 21 March 2024
Available online 19 May 2024

Keywords:
IoT
Blockchain
ECC
Identity authentication
Security

ABSTRACT

In the Internet of Things (IoT), a large number of devices are connected using a variety of communication technologies to ensure that they can communicate both physically and over the network. However, devices face the challenge of a single point of failure, a malicious user may forge device identity to gain access and jeopardize system security. In addition, devices collect and transmit sensitive data, and the data can be accessed or stolen by unauthorized user, leading to privacy breaches, which posed a significant risk to both the confidentiality of user information and the protection of device integrity. Therefore, in order to solve the above problems and realize the secure transmission of data, this paper proposed EBIAS, a secure and efficient blockchain-based identity authentication scheme designed for IoT devices. First, EBIAS combined the Elliptic Curve Cryptography (ECC) algorithm and the SHA-256 algorithm to achieve encrypted communication of the sensitive data. Second, EBIAS integrated blockchain to tackle the single point of failure and ensure the integrity of the sensitive data. Finally, we performed security analysis and conducted sufficient experiment. The analysis and experimental results demonstrate that EBIAS has certain improvements on security and performance compared with the previous schemes, which further proves the feasibility and effectiveness of EBIAS.

© 2024 The Author(s). Published by Elsevier B.V. on behalf of Shandong University. This is an open access article under the CC BY-NC-ND license (http://creativecommons.org/licenses/by-nc-nd/4.0/).

1. Introduction

As IoT technology continues to advance, an increasing number of devices and sensors are becoming interconnected within the network. Therefore, different types of devices have the capability to communicate and work together seamlessly so as to realize data collection, transmission, processing and application. Multiple devices can share data and resources, greatly improving the speed and efficiency of information transmission [1,2]. IoT has a wide range of application scenarios, including industrial automation, smart agriculture, smart city and smart home [3,4]. The IoT technology has significantly influenced the progress of society by bolstering efficiency, sustainability, and intelligence across various domains. However, IoT devices also suffer from single point of failure, data security and privacy leakage [5]. Therefore, identity authentication schemes for IoT devices are crucial in ensuring the legitimate identity of participants. Unfortunately, data information is often transmitted over insecure channels, data security can not be guaranteed.

Authentication is widely used to secure data and the identity of devices. With a view to better tackle the security concerns faced by IoT devices, researchers have started to implement blockchain technology to IoT device identity authentication [6,7]. Blockchain is a decentralized, distributed database that ensures data security and untamperability through cryptographic algorithms and consensus mechanisms. Blockchain-based authentication schemes have many advantages. First, due to the decentralized nature of blockchain, the risk of single point of failure and centralized identity management is eliminated. Second, by using cryptographic algorithms, advanced encryption techniques are employed to guarantee the confidentiality and integrity of data during transmission and storage [8]. At the same time, a strong authentication and authorization mechanism is implemented to verify that only authorized devices and users can access and operate critical data. Strong authentication and data encryption are provided for the blockchain to guarantee the secrecy and integrity of communications [9]. Most importantly, blockchain technology provides an untamperable identity

* Corresponding author.
E-mail address: anmingdong@qlu.edu.cn (A. Dong).

https://doi.org/10.1016/j.hcc.2024.100240
2667-2952/© 2024 The Author(s). Published by Elsevier B.V. on behalf of Shandong University. This is an open access article under the CC BY-NC-ND license (http://creativecommons.org/licenses/by-nc-nd/4.0/).

record, making it impossible to forge or tamper with the device identity information and enhance the credibility of identity authentication [10].

1.1. Motivation

The advancement of IoT technology has undoubtedly improved the speed and efficiency of information transmission, but the communication security and privacy protection issues are still significant. There is a growing concern about how to design and implement a secure identity authentication scheme for IoT devices. Moreover, there is also a need to address some of the security issues in the identity authentication of IoT devices. All of them are highlighted below.

(1) The proliferation of IoT devices, many of which have direct access to sensitive information, increases the security risk of information leakage, and the identity of the devices needs to be authenticated.

(2) IoT devices are subject to a variety of attacks when exchanging data, such as replay attacks, etc., and the real identity of the device can easily be stolen by attackers.

(3) Excessive computational storage overhead has also become a major limiting factor in the authentication process of IoT devices.

1.2. Contribution

To address these challenges and achieve secure identity authentication for IoT devices, blockchain technology can be utilized and combined with ECC algorithm and SHA-256 algorithm. IoT device identity authentication is conducted to address data security issues.

Building upon the preceding discussion, the primary contributions and concepts of this paper can be summarized as follows:

(1) We propose a blockchain-based IoT device authentication scheme EBIAS to realize efficient device identity authentication.

(2) EBIAS provides better security against attacks such as replay attacks, man-in-the-middle attacks and Denial of Service(DoS) attacks, and also features device anonymization, forward secrecy and mutual authentication.

(3) We conducted sufficient experiments on the computation, storage and communication costs of EBIAS. The experimental results show that EBIAS has lower cost and higher security compared with other schemes.

The remainder of this article is organized as follows. Section 2 provides an overview of prior research concerning IoT device authentication. Section 3 introduces the basic concepts such as blockchain and ECC algorithms. Section 4 details the design and implementation of EBIAS, the identity authentication scheme for IoT devices proposed in this paper. Section 5 verifies the feasibility and validity of EBIAS through experimental results. Finally, Section 6 concludes this paper with a recap and future prospects.

2. Related work

In this section, we present some state-of-the-art identity authentication schemes and the existing blockchain-based identity authentication schemes.

2.1. Identification scheme

In [11], Xie et al. highlighted the recurring issues in prior authenticated key agreement schemes, including the risk of lost smart card attacks, offline dictionary attacks, desynchronization attacks, absence of forward secrecy, user anonymity, and untraceability. Subsequently, they introduced an Authentication and Key Agreement (AKA) scheme with anonymity, rooted in dynamic identity, asserting that their solution resolves all the aforementioned issues. In [12], Abbasinezhad-Mood et al. identified vulnerabilities in the aforementioned scheme [11], including susceptibility to key disclosure simulation attacks, session-specific temporary information attacks, and denial of service attacks.

In [13], Li et al. addressed this issue and introduced a novel scheme to safeguard user anonymity. In the registration process, user identity ID_{IAC} are not transmitted directly, each user ID is stored in the Registration Center (RC). The challenge here is that the Registration Center RC must remain continuously online throughout the authentication process. In [14], Jia et al. identified multiple attacks within [13], including emulation attacks, replay attacks, stolen authenticator attacks, and DoS attacks. At the same time, Shamshad et al. [15] assessed the susceptibility of Li et al. [13] scheme to stolen authentication attacks.

2.2. Symmetric keys scheme

In [16], Braeken devised a symmetric key-based authentication scheme for communication between servers and sensors. However, in the authentication scheme they proposed without storage, the shared key remains unaltered. It's important to highlight that there is supplementary information in addition to the shared key for identity authentication. Despite the fact that the auxiliary information is refreshed in every session, it is sent over a public channel. This implies that if the shared key is ever breached, the previous session becomes vulnerable.

In [17], Alzahrani et al. formulated an enhanced lightweight authentication scheme building upon [18]. The user and the gateway, as well as the gateway and the IoT device, each possess a shared key and utilize them to ensure the integrity of the messages. Crucially, the shared key remains unchanged throughout the session. In other words, if an adversary compromises an IoT device or a user and acquires its shared key, they can access all messages, including the session key. In the scheme of Ghani et al. [19], keys are exchanged between neighboring layers within the authentication process, and their authentication method closely resembles that of [17]. In simpler terms, they face the same issue as [17], which is that if any shared key is compromised, the communication channel becomes insecure.

2.3. Certificate scheme

In [20], Liu et al. introduced a blockchain-based unlinkable authentication protocol that permits the creation of multiple pseudonyms. Since pseudonyms are verified by data within a particular block, there is no efficient method for revoking access in response to malicious attacks. In order to achieve transparency of certificates and revocations, Sang et al. [21] introduced an efficient privacy-preserving authentication scheme known as on-chain certificate management (PACM) in VANET. In this scheme, the service manager (SM) of each domain functions as a blockchain node to establish a distributed system.

In [22], Feng et al. suggested a privacy-preserving authentication system aided by blockchain technology, utilizing smart contracts to document and revoke pseudonyms and public keys. During each authentication, the recipient is required to request the sender's public key from the blockchain manager via the smart contract, resulting in a notable increase in authentication overhead. In [23], Garba et al. proposed a lightweight certificate of size LightCert4IoTs, which is not issued by a Certificate Authority (CA). The existing challenges of Public Key Infrastructure (PKI) certificates in IoT devices are addressed by utilizing the benefits of blockchain technology and smart contracts for more secure

and efficient certificate issuance, renewal and revocation. But the solution has scalability issues.

In the above methods, the identity authentication scheme of the device faces the problems of single point of failure, man-in-the-middle attack and the anonymity of the device cannot be guaranteed. In the process of the implementation of the identity authentication scheme, it is easy to produce the management problems of the storage, distribution and update of the key, resulting in the key leakage. To address the previously mentioned issues, this paper puts forward an identity authentication scheme for IoT devices based on blockchain and ECC algorithm. It guarantees the security and reliability of identity data and provides a more secure and reliable solution for identity authentication.

3. Preliminary

In this section, we briefly review the relevant techniques needed and introduce the ECC algorithm and the SHA-256 algorithm.

3.1. Blockchain

Blockchain constitutes a decentralized distributed data-base system upheld by all nodes within the blockchain network [24]. Comprising a series of data blocks created using cryptographic techniques, each of them serves as a block within the blockchain. A data chain is formed by methodically connecting blocks in the sequence of their generation. The linking of blocks is accomplished by the hash value of the data in the block header [25]. This hash value serves as a unique identifier for each block in the blockchain, allowing the identification of a connected block within the blockchain through the hash value of its parent block, recorded in the block header. In this manner, a chain is formed, starting from the latest block and extending to the initial block. This chain is constructed through a series of hash connections between each block and its parent block, yielding a linked-like data structure comprising all the blocks. Thus, the blockchain is aptly designed for building decentralized networks, simultaneously providing resilience against tampering. At the same time, cryptography technology can be combined to ensure security [26].

3.2. Smart contract

Nick Szabo introduced this concept in 1994 and defined a smart contract as "a computerized transaction protocol that executes the terms of a contract" [27]. Smart contracts are scripts stored on the blockchain. Since they reside on the chain, they have a unique address. We trigger a smart contract by addressing a transaction to it. It then executes independently and automatically in a prescribed manner on every node in the network, according to the data that was included in the triggering transaction. Smart contracts operate as autonomous actors, whose behavior is completely predictable. As such they can be trusted to drive forward any on-chain logic that can be expressed as a function of on-chain data inputs, provided that the data they need to manage is within their own reach [28].

3.3. ECC algorithm

Indra and Taneja proposed ECC, the security of ECC relies on the computational complexity of elliptic curve discrete groups [29]. The optimal solution to this issue involves exponential-time algorithms. In general, Rivest-Shamir-Adleman (RSA) and Diffie–Hellman (DH) key exchange protocols demand over 1024 bits of modulus for security, whereas for ECC, merely 160 bits of modulus can deliver an equivalent level of security.

ECC offers several advantages, including achieving strong security with shorter keys, generating compact digital signatures and certificates, and performing speedy computations. These advantages have led to widespread adoption of the ECC public key algorithm in the field of cryptography [30].

Elliptic curve $Ep(a, b)$, p is prime, $x, y \in [0, p-1]$:

$y^2 = x^3 + ax + b \ (mod\ p)$

where the curve is required to be nonsingular (conductible everywhere), there is $4a^3 + 27b^2 \neq 0$.

First construct an elliptic curve E, choose a point G on the curve as the generating element, and find the order of G to be n. The requirement is that n must be prime; Choose a private key k $(k < n)$ and generate a public key $Q = k * G$; Send the public key set E, Q, G.

3.4. SHA-256 algorithm

SHA-256 algorithm generates a message digest of length 256 bits. SHA-256 falls under the security category, as it is designed to make it infeasible to derive different messages from the same message digest. The process of generating a message digest in this algorithm comprises five steps: message padding, adding bit length, initializing the initial hash, value processing and finalization [31].

The message is first segmented to generate a block of 512 bits in length, appending the bit count in the final message block, which is 448 bits longer than the specified length, to make it a total of 512 bits. Then the initial and interim output values within the SHA-256 hash function are processed for one value using the buffer value. Finally, a 256-bit message digest is generated.

SHA-256 is a one-way hash function, it cannot reverse the original input data from the hash value. This ensures that the device identity information cannot be easily recovered or forged. Even with small changes in the input data, the hash value produced by SHA-256 will be significantly different. Each device has a unique hash identifier, helping to ensure the uniqueness of the device identity.

4. ECC-enabled blockchain-based identity authentication scheme (EBIAS)

In this section, we present an identity authentication scheme for IoT devices relied on ECC algorithm. It is a scheme for authenticating IoT devices for security issues. The implementation of this scheme is discussed below.

4.1. EBIAS description

The design of the EBIAS scheme is illustrated in Fig. 1, consisting of four main entities: User, IoT device, Blockchain, and an Identity Authentication Center. That are described as follows:

User (U_i): U_i are entities that interact with and manage IoT devices. They may need to access device data or control device operations. They obtain legitimate access permissions by authenticating their identities through the identity authentication center.

IoT device (D_i): D_i are entities that require identity authentication. They can be sensors, smart devices, or other terminals connected to the IoT. Each device is equipped with a distinct identifier and possesses associated public and private keys.

Blockchain (BC): BC serves as a distributed public ledger used to store and validate identity information of D_i and authentication-related data. It consists of multiple nodes, each having a complete replica of the blockchain, and ensures network security and consistency through consensus algorithms.

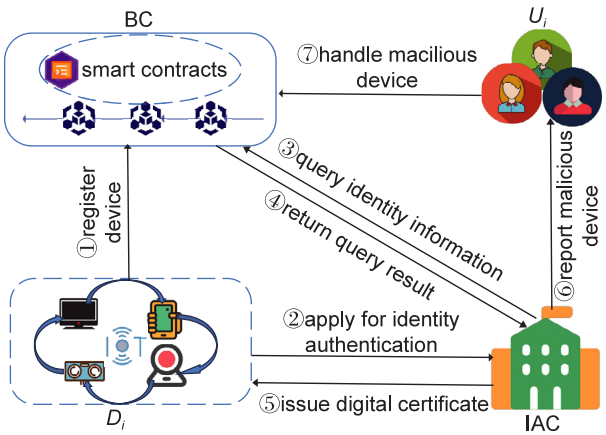

Fig. 1. EBIAS scheme.

Table 1
Notations used in EBIAS.

Notation	Description
D_i	Device
IAC	Identity authentication center
PW_i	Di password
ID_i	Device ID
ID_{IAC}	IAC ID
X	Secret key of IAC
CK	Encryption key
PID_i	Device identity identifier
A	The adversary
$H(.)$	A hash function transforms into a string of length H bits
$h(.)$	SHA-256 hash function
G	Generator point of order n
SK	Session key
EXP_Time	Time limit for device
$T_1/T_2/T_3/T_4$	Timestamp
$\|\|$	The logical operation of "OR"
$\oplus$	The exclusive or (XOR) operation

Identity Authentication Center (*IAC*): *IAC* is the core component responsible for managing and verifying device identities. It maintains the identity registry in the blockchain network, which includes the unique identifiers, public keys, and other identity information of each device. When a device needs to be identity authentication, it sends a request to the *IAC* and undergoes the verification process.

4.2. Implementation steps

The blockchain-based IoT device identity authentication scheme EBIAS proposed in this article consists of three main modules: identity registration, identity authentication, and identity management.

Identity registration: When a new D_i needs to join the IoT, it undergoes identity registration. It generates a public–private key pair and transmits the public key for registration in the blockchain network. While registering, the D_i provides basic information such as device model and manufacturer, which is recorded in the blockchain. After completing identity registration, D_i can communicate with other devices in the IoT.

Identity authentication: When users access D_i, they need to be authenticated to ensure the security of the D_i. The device obtains the public key of the blockchain network, and then uses the public key for encryption and signature. The recipient uses the corresponding private key for decryption and verification. If the authentication succeeds, the identity authentication of both parties is considered successful.

Identity management: Situations such as device loss or theft may occur during usage, making identity management critical. Administrators can remove the device public key from the blockchain, preventing malicious use of stolen devices.

Next, we give an elaborate explanation of EBIAS. The scheme consists of the following 6 stages. Table 1 presents the symbols used in this paper.

Stage 1. Generating public–private key pair

Generate a public–private key pair for D_i using the ECC algorithm. Choose appropriate curve parameters and generate a random number for the private key. Use the ECC algorithm to generate a public key, which will serve as the unique identity of the D_i.

Select a base point (also known as the generator point) from the chosen elliptic curve, typically denoted as G. Randomly choose a private key (a random large integer), usually represented by the letter $priK$. Using the private key and the base point, calculate the public key (a point on the elliptic curve) using the following formula: $pubK = priK * G$. The generated private and public keys constitute a key pair, where the private key serves for signing and decryption, while the public key is utilized for verification and encryption.

Stage 2. Hashing

The public key of D_i is hashed using the SHA-256 algorithm to generate a fixed-length digest. SHA-256 is a commonly used hash function that can map data of any length to a 256-bit hash value.

Apply the SHA-256 hash operation to the generated public key to obtain the public key hash. The public key hash is used to identify the D_i identity. The input data, such as the public key, is transformed into a fixed-length hash value: $H = h(pubK)$, where h represents the SHA-256 hash function.

Stage 3. Registering device identity

Upload the D_i public key and hash value to the identity registration contract on the *BC*. This contract can be a smart contract responsible for managing and verifying D_i identity information.

Step 1: Register D_i with *IAC*. First, D_i computes $I_i = h(ID_i \| PW_i)$, where ID_i represents the identity information of D_i, and PW_i represents the access credential utilized to access D_i, D_i transmits the generated information to the *IAC* via a secure communication channel.

Step 2: Upon receiving the information sent by D_i, *IAC* generates a random sequence R_i of length l_h and calculates $PID_i = h(R_i \| ID_{IAC} \| I_i) \oplus ID_{IAC}$. Additionally, $CK = h(R_i \| X \| EXP_time \| PID_i)$, $CK' = CK * G$, $T_i = R_i \oplus h(X \| PIDi)$, $A_i = h(T_i \oplus I_i \oplus CK')$, and $A_i' = A_i * G$. *IAC* then preserves the received and produced information $\{A_i', PID_i, EXP_time\}$. D_i securely sends the generated registration information $\{PID_i, CK', T_i\}$ to the *BC* via a secure channel.

Stage 4. Identity authentication

When a D_i needs to undergo identity authentication, it sends its public key and a random number to the *IAC*. Upon receiving the D_i public key, the *IAC* uses the same hash function (SHA-256) to hash the public key and generate a hash value. *IAC* queries the identity registration contract on the *BC* to verify if the hash value exists in the contract. If it does, it indicates that the D_i identity information is valid.

Step 1: To access the *IAC*, D_i chooses a random value N_1 of length l_h and creates a timestamp T_1. Then, D_i calculates $P_1 = N_1 * G$, $P_2 = h(N_1 * CK')$, $Y = h(P_1 \| P_2 \| T_1)$. Next, D_i sends a login request message $\{PID_i, P_1, Y, T_1\}$ to the *IAC*.

Step 2: Upon receiving the message from D_i, *IAC* retrieves the current timestamp T_2 and verifies whether $T_2 - T_1$ is smaller

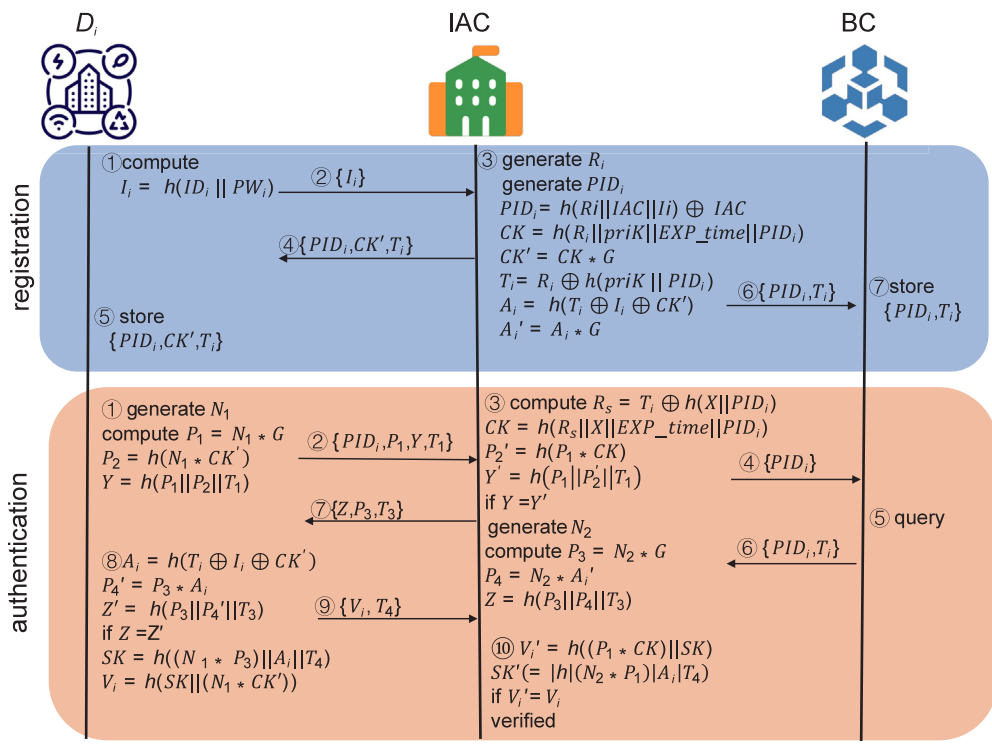

Fig. 2. Registration and authentication phase.

than ΔT. If true, *IAC* uses PID_i to search its internal database and retrieve the pertinent information for PID_i. Simultaneously, *IAC* sends a request to the *BC*, which uses PID_i to query the corresponding T_i in the database and returns $\{PID_i, T_i, EXP_time\}$ to *IAC* for checking if *EXP_time* has expired. If *EXP_time* has not expired, *IAC* calculates the information $R_s = T_i \oplus h(X\|PID_i)$, $CK = h(R_s\|X\|EXP_time\|PID_i)$, $P_2' = h(P_1 * CK)$. Then, *IAC* verifies if $Y' = h(P_1\|P_2'\|T_1)$ is equal to Y. If unequal, the access request is rejected. Otherwise, the next step is performed.

Step 3: *IAC* generates a random value N_2 and obtains the current timestamp T_3, calculates $P_3 = N_2 * G$, $P_4 = N_2 * A_i'$, $Z = h(P_3\|P_4\|T_3)$. Then, *IAC* sends $\{Z, P_3, T_3\}$ to D_i.

Step 4: Upon receiving $\{Z, P_3, T_3\}$ from *IAC*, D_i obtains the current timestamp T_4 and checks if $T_4 - T_3$ is less than ΔT to guarantee the message recentness. If the message is recent, D_i calculates $A_i = h(T_i \oplus I_i \oplus CK')$, $P_4' = P_3 * A_i$, $Z' = h(P_3\|P_4'\|T_3)$. Then, D_i verifies *IAC* authenticity by checking if Z' is equal to Z. If unequal, the request is declined; Otherwise, D_i proceeds to the next step.

Step 5: D_i calculates the value $V_i = h(SK\|(N_1 * CK'))$, $SK = h((N_1 * P_3)\|A_i\|T_4)$. Then, D_i generates a timestamp T_4 for the current time and sends $\{V_i, T_4\}$ to *IAC*.

Step 6: When *IAC* receives $\{V_i, T_4\}$, *IAC* obtains the current timestamp T_5 and checks if $T_5 - T_4$ is less than ΔT. If true, *IAC* calculates $V_i' = h((P_1 * CK)\|SK)$. Next, *IAC* verifies if V_i and V_i' are equal. If they are not, *IAC* declines the access request. Otherwise, *IAC* accepts the access request and calculates $SK' = h((N_2 * P_1)\|A_i\|T_4)$. Subsequently, the session between *IAC* and D_i is encrypted using the session key SK.

Fig. 2 depicts the comprehensive process of the registration and authentication phase.

Stage 5. Authorization access

If the identity authentication is successful, the *IAC* can issue a digital certificate to the device, confirming that the device identity has been verified. The digital certificate contains the information $\{ID_i, pubK, infoCA, T^*, signIAC\}$, where *infoCA* represents the issuer information, T^* represents the validity period of the certificate, and *signIAC* represents the issuer digital signature. The device can use this certificate to securely communicate with other systems and obtain authorized access.

Stage 6. Identity management

During the D_i usage, if the U_i fails the identity authentication during the access process, it means that there is a security problem with D_i. In such cases, it is necessary to revoke the D_i identity information. The administrator removes the D_i public key from the *BC* to prevent malicious use of the D_i.

4.3. Security analysis

The proposed solution utilizes blockchain technology for device identity authentication, combined with the public–private key system of the ECC algorithm and the hash function of the SHA-256 algorithm, to ensure the uniqueness, integrity, and security of device identity. By employing digital signatures and hash functions, a trustworthy identity authentication system can be established. We will assess the security of the proposed solution by examining various intrusion techniques. We illustrate EBIAS ability to offer the subsequent security capabilities and safeguard against the following types of attacks.

Proposition 1. *EBIAS can resist attempts of guessing passwords and identities.*

Proof. In EBIAS, during the device registration phase, D_i transmits I_i (where $I_i = h(ID_i\|PW_i)$) to *IAC* through a secure channel. Therefore, due to the irreversible nature of the hash function, an attacker A cannot compute D_i and PW_i.

The use of tamper-resistant devices protects the information stored within the devices from being stolen by attackers. Let's assume that A intercepts the information $\{PID_i, P_1, Y, T_1\}$ when D_i logs in, where $P_1 = N_1 * G$, $P_2 = h(N_1 * CK')$, $Y = h(P_1\|P_2\|T_1)$.

$P_i = h(R_i \| D_s \| I_i) \oplus ID_s$ is safeguarded by the private key, random numbers and the hash function, it becomes impractical to deduce the accurate identity through guessing. Hence, EBIAS can effectively resist the attack.

Proposition 2. *EBIAS can resist replay attacks.*

Proof. Replay attack is when an adversary intercepts a message and resends it to the *IAC* to obtain authentication. In EBIAS, A can intercept the message $\{PID_i, P_1, Y, T_1\}$. In the event that the replay happens during the specified time interval, *IAC* responds with the message $\{Z, P_3, T_3\}$. However, upon receiving the response message from the *IAC*, A lacks knowledge of I_i, making it impossible for A to compute A_i, where $A_i = h(T_i \oplus I_i \oplus CK')$ and SK. As a result, replay attacks instigated by A cannot extract any meaningful information.

Suppose A obtains the message $\{PID_i, P_1, Y, T_1\}$ through the public channel. We permit A to execute replay attacks without altering $\{PID_i, P_1, Y, T_1\}$. In EBIAS, a timestamp is generated with each message to identify legitimate requests. Therefore, EBIAS can resist replay attacks. Even if A obtains the message $\{PID_i, P_1, Y, T_1\}$ from the public channel and attempts to replay it without modification, the new message will be associated with a new timestamp (T_2) when it is resent. Since verifies the freshness of the timestamp, it ensures the time interval between T_2 and T_1 is verified. If the time interval exceeds the predefined threshold, rejects the message, and the replay attack fails. Thus, based on the usage of timestamps in the scheme, EBIAS effectively defends against replay attacks.

Proposition 3. *EBIAS is resistant to man-in-the-middle attacks.*

Proof. When A carries out a man-in-the-middle attack, they may gather communication parameters like CK, P_1, P_2, P_3, P_4, etc. The computation of P_1 and P_3 requires the generation of random numbers N_1 and N_2, which A cannot replicate through eavesdropping and computation. Because of the inherent mathematical difficulties of ECC, A is unable to calculate points on the ECC and solve the Elliptic Curve Discrete Logarithm Problem (ECDLP) in feasible time. Therefore, EBIAS can withstand man-in-the-middle attacks.

Proposition 4. *EBIAS is resistant to insider attacks.*

Proof. If A impersonates a legitimate device for malicious operations, they would need to obtain PW_i. Within EBIAS, during the device registration phase, D_i sends I_i to the *IAC*, where $I_i = h(ID_i \| PW_i)$. Therefore, insiders cannot retrieve PW_i through I_i, as the hash function is irreversible. As mentioned in *Proposition* 1, it is not possible for insiders to successfully guess the correct device password. Hence, EBIAS can withstand privileged insider attacks.

Proposition 5. *EBIAS can resist session key theft attacks.*

Proof. Let's consider that A somehow obtains the session key between D_i and *IAC*. According to EBIAS, A cannot obtain CK' as SK is safeguarded by an unrecoverable hash function. Even if A gains access to SK, they cannot impersonate a legitimate device for authentication. Additionally, A cannot access the information about D_i stored on *IAC*. Therefore, EBIAS prevents A from successfully executing session key theft attacks.

Proposition 6. *EBIAS can maintain the anonymity of device.*

Proof. During the sign-in authentication phase, D_i transmits the sign-in message $\{PID_i, P_1, Y, T_1\}$ to *IAC*, where $P_1 = N_1 * G$, $P_2 = h(N_1 * CK')$, and $PID_i = h(R_i \| ID_s \| I_i) \oplus ID_s$. PID_i represents a pseudonymous identity for D_i, protected by the use of *ID*, random numbers, and hash functions. D_i is not sent via open communication channels and is also not stored within D_i or *IAC* databases. This demonstrates that EBIAS can provide device anonymity.

Proposition 7. *EBIAS can maintain perfect forward secrecy.*

Proof. Forward secrecy significance is rooted in the fact that, should A somehow come into possession of PW_i and X, A threat will have no impact on the integrity of the past session SK. Let's assume that PW_i and X have been leaked to A. Since the generation of SK depends only on $\{N_1, N_2, A_i\}$, and only X in possession, the session keys from previous sessions remain uncompromised. Therefore, this demonstrates perfect forward secrecy.

Proposition 8. *EBIAS can ensure mutual authentication.*

Proof. Within EBIAS, for the purpose of authenticating devices, D_i first sends $Y = h(P_1 \| P_2 \| T_1)$ to *IAC*, and *IAC* checks if Y' is equal to Y. $P_1 = N_1 * G$, $P_2 = h(N_1 * CK')$, where CK' is possessed only by authorized devices. A is unable to acquire CK', and therefore cannot compute SK. Additionally, A cannot compute $V_i = h(SK \| (N_1 * CK'))$ for verification by *IAC*. This approach allows to confirm the valid identity of the device. Furthermore, *IAC* transmits $Z = h(P_3 \| P_4 \| T_3)$ to D_i, and D_i validates Z' by computing Z using $\{P_3, P_4\}$, which require the use of CK. Only the legitimate possesses CK. CK is computed and stored only by the *IAC*, making it impossible for an attacker to forge. Therefore, EBIAS achieves mutual authentication.

Proposition 9. *EBIAS can resist cookie theft attacks.*

Proof. Suppose A intends to log in to the *IAC* by obtaining CK, where $CK = h(R_s \| X \| EXP_time \| PID_i)$. In EBIAS, D_i does not transmit CK through any public channel to the *IAC*. Due to the protection of the hash function, A cannot acquire any additional information through CK. Therefore, EBIAS prevents A from successfully executing cookie theft attacks.

Proposition 10. *EBIAS can resist Key Compromise Impersonation (KCI) attacks.*

Proof. Suppose A manages to compromise the *IAC* and gain access to the *IAC* private key X. Now, A attempts to compute $CK = h(R_s \| X \| EXP_time \| PID_i)$. T_i is stored on the *IAC*, accessible only through the internal network, and neither transmitted through open channels nor computable. Therefore, A cannot recompute CK. It is impossible for A to simultaneously compromise *IAC*. When the *IAC* security is upheld, the feasibility of KCI attacks is eradicated.

5. Experiment

Within this section, we shall conduct a comparative analysis of EBIAS in relation to other schemes, focusing on both security and performance aspects.

5.1. Experiment setup

This experimental environment contains the necessary entities including U_i, D_i, *BC*, and *IAC*. The experimental validation operations were all performed on a desktop machine with an Intel(R) Core(TM) i7-8700K CPU @ 3.70 GHz and 16.0 GB of RAM. All machines are interconnected in a local network. Under Windows 10 operating system, FISCO-BCOS was installed. We adopted the

Table 2
Efficiency comparison.

Scheme	Total	Time (ms)
[32]	10Tp + 11Th	22.1936
[33]	6Tp + 22Th	13.6026
[34]	6Tp + 14Th	13.4538
[35]	3Tp + 18Th	6.9315
[36]	6Tx + 15Th	6.3108
EBIAS	6Tp + 8Th	13.3422

Solidity language to write the Solidity code for the smart contract, including the authentication logic and digital certificate generation and validation functions. Moreover, we utilized the tools to deploy the smart contract into the blockchain network. We write Python scripts to implement the device authentication logic. Interact with the smart contract for device registration, authentication and digital certificate generation and verification. Test the authentication and record the results of the experiments.

5.2. Experiment analysis

For evaluating the algorithm time efficiency, we establish the subsequent metrics.

T_h - Hash operation time.

T_p - ECC point multiplication execution time.

The computation time of T_x - modular exponentiation.

For computational convenience and with reference to the research results on the improvement of other authentication schemes, we specify that D_i, PW_i, random numbers, and hash functions are 160 bits, points on the elliptic consist of 320 bits, while the secret key length is 1024 bits. Similarly, We conducted experiments based on the previously improved authentication scheme and calculated the time consumed by T_h, T_p.

5.2.1. Efficiency comparison

Our primary focus lies in computing the computational cost of the authentication phase since this phase is executed more frequently than the others. Furthermore, we exclude computational costs such as dissimilarity comparisons, as they entail minimal expenses in cryptography. Table 2 gives several other authentication schemes an improved IoT authentication scheme [32], a forward secrecy user authentication scheme [33], a scheme for authentication and key exchange based on anonymous signatures [34], a lightweight scheme for preserving privacy and enabling anonymous authentication in the context of IIoT using WSNs [35], and a scheme for secure remote user authentication with key agreement designed for cloud environments [36]. We conducted computational costing experiments on the above schemes, and our computational cost is segmented into two components: the computational cost incurred by the IoT device and the computational cost borne by the authentication center. The total computational cost of the authentication process we are interested in is the sum of these two components.

As evident from Table 2 and Fig. 3, the computational cost of EBIAS is marginally greater than schemes proposed by [35,36]. But EBIAS is resistant to DOS attack and KCI attack and also has device anonymity for better security. Therefore, the added time cost is fully justified when considering the scheme improved security. Other schemes incur higher computational costs than EBIAS and are vulnerable to various security threats that necessitate the application of different computational methods for mitigation. So EBIAS has a definite advantage in terms of security.

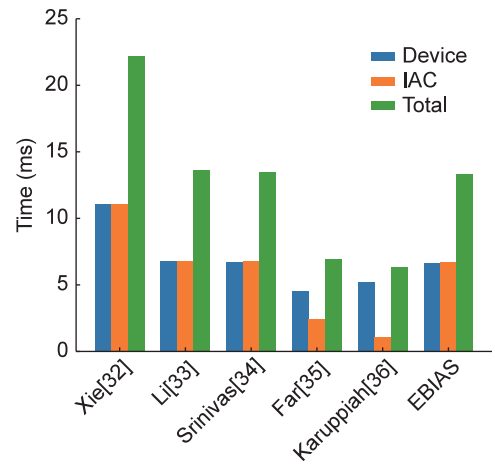

Fig. 3. Efficiency comparison.

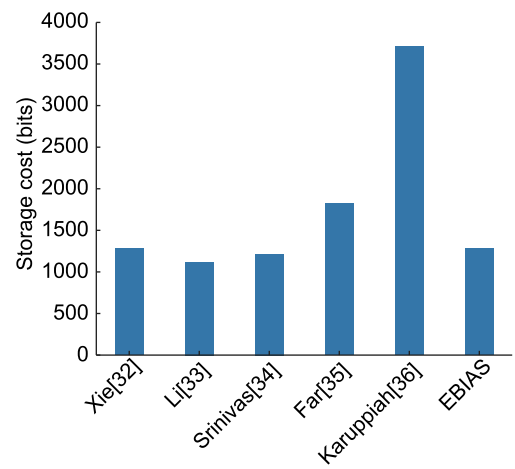

Fig. 4. Storage cost comparison.

5.2.2. Storage cost comparison

The calculation of the storage cost for EBIAS is as follows: To store the message $\{PID_i, T_i\}$ requires (160 + 160) = 320 bits; 160 + 320 + 160 = 640 bits are needed to store $\{PID_i, CK', T_i\}$ in the device. The shared key SK, which is stored on both the device and the blockchain, occupies 320 bits in total (160 bits each). Overall, EBIAS incurs a storage cost of 1280 bits.

The storage costs of the other schemes are calculated individually as follows: [32] has a storage cost of 1280 bits, [33] requires 1120 bits, [34] incurs 1216 bits , [35] necessitates 1824 bits, and [36] has a storage cost of 3712 bits. The storage cost of EBIAS is slightly higher than the two schemes [33,34] but lower than the other authentication schemes. EBIAS greatly improves the security of authentication with relatively small storage cost.

Fig. 4 illustrates the storage costs associated with each scheme.

5.2.3. Communication cost comparison

The calculation of the communication overhead for EBIAS is as follows: messages require (160+320+160)=640 bits, messages communicating with devices require (160+160+160) = 480 bits, and messages communicating with devices require (160+160+160) = 480 bits. Messages Z, P_3, and T_3 require (160+320) = 480 bits, and messages V_1 and T_4 require 160 bits. In summary, the total communication overhead for EBIAS amounts to 1760 bits.

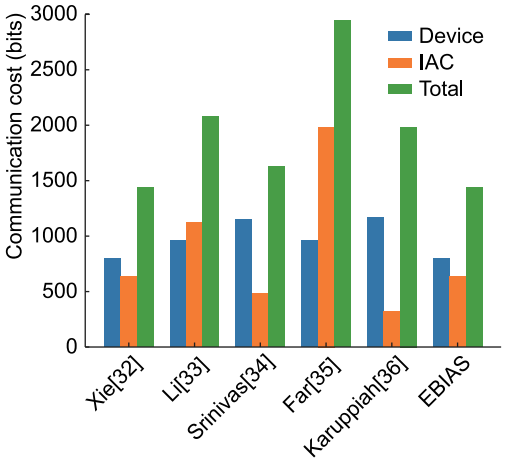

Fig. 5. Communication cost comparison.

Table 3
Communication cost comparison.

Scheme	Device	IAC	Total (bits)
[32]	480	1280	1760
[33]	960	1120	2080
[34]	1152	480	1632
[35]	960	1984	2944
[36]	1164	320	1984
EBIAS	480	1280	1760

The communication schemes [32–35], and [36] have overheads of 1760, 2080, 1632, 2944, and 1984 bits, respectively. EBIAS has the same cost as [32] scheme with the same communication cost. However, [33,35,36] schemes have lower communication cost compared to EBIAS. Moreover, EBIAS has better security and hence the scheme is feasible.

Table 3 and Fig. 5 provide a comparison of the communication costs among various schemes.

5.2.4. Security assessment

Based on our previous security analysis, it is evident that EBIAS can withstand various attacks, including password guessing attacks, replay attacks, man-in-the-middle attacks, session key attacks, and DoS attacks. Moreover, EBIAS has device anonymity and forward secrecy, and it can also carry out mutual authentication between devices. Table 4 presents a comparative analysis between related schemes [32–36] and EBIAS.

Table 4 shows that EBIAS can resist various attacks. For example, scheme [34] is not resistant to replay attacks, and schemes [33, 36] are not resistant to password guessing attacks. Schemes such as [32–35] cannot resist DoS attacks, and schemes such as [33–36] will be threatened by KCI attacks. It's worth noting that the schemes presented in [33,34] lack forward secrecy, and those in [33,34,36] do not attain mutual authentication.

Therefore, EBIAS exhibits robustness and significant security advantages when confronted with a wide range of attacks.

6. Conclusion

This paper introduces a blockchain-based identity authentication scheme, EBIAS, designed for IoT devices. EBIAS is proposed, introduced, and implemented in detail. EBIAS offers the benefits of decentralization, tamper resistance, traceability, and high security. These advantages effectively address the challenges in identity authentication for IoT devices. The EBIAS can provide effective protection for the security of IoT devices and has a wide range of application prospects.

Table 4
Comparison of security requirements.

Security	[32]	[33]	[34]	[35]	[36]	EBIAS
S1	✓	×	✓	✓	×	✓
S2	✓	✓	✓	✓	×	✓
S3	✓	✓	×	✓	✓	✓
S4	✓	✓	✓	✓	×	✓
S5	✓	✓	×	✓	✓	✓
S6	×	×	✓	×	×	✓
S7	✓	✓	×	✓	×	✓
S8	✓	×	×	✓	×	✓
S9	×	✓	×	×	×	✓
S10	✓	×	×	×	×	✓

* S1 to S10 correspond to the attacks analyzed above.
* the ✓ indicates the schema can resist the attack.
* the × indicates the schema can not resist the attack.

In short, the identity authentication scheme of IoT devices based on blockchain is of great significance, which can provide effective protection for the security of IoT devices. In future research, we will persist in our efforts to explore more efficient and secure identity authentication schemes for IoT devices, with the aim of making substantial contributions to the advancement of IoT technology.

CRediT authorship contribution statement

Wenyue Wang: Conceptualization, Methodology, Software, Validation, Formal analysis, Data curation, Writing–original draft. **Biwei Yan:** Methodology, Writing–review & editing, Supervision. **Baobao Chai:** Conceptualization, Formal analysis, Investigation, Supervision. **Ruiyao Shen:** Methodology, Formal analysis, Visualization. **Anming Dong:** Writing–review & editing, Supervision. **Jiguo Yu:** Writing–review & editing, Supervision, Project administration, Funding acquisition.

Declaration of competing interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Acknowledgments

This work was supported by the National Science Foundation of China (62272256, 62202250), the Major Program of Shandong Provincial Natural Science Foundation for the Fundamental Research (ZR2022ZD03), the National Science Foundation of Shandong Province (ZR2021QF079), the Talent Cultivation Promotion Program of Computer Science and Technology in Qilu University of Technology (Shandong Academy of Sciences) (2023PY059), the Pilot Project for Integrated Innovation of Science, Education and Industry of Qilu University of Technology (Shandong Academy of Sciences) (2022XD001), and the Colleges and Universities 20 Terms Foundation of Jinan City (202228093).

References

[1] P. Zhang, C. Wang, N. Kumar, L. Liu, Space-air-ground integrated multi-domain network resource orchestration based on virtual network architecture: A DRL method, IEEE Trans. Intell. Transp. Syst. 23 (2022) 2798–2808.

[2] T. Zhou, J. Shen, Y. Ren, S. Ji, Threshold key management scheme for blockchain-based intelligent transportation systems, Secur. Commun. Netw. 2021 (2021) 1864514:1–1864514:8.

[3] G.S. Aujla, A. Jindal, A decoupled blockchain approach for edge-envisioned IoT-based healthcare monitoring, IEEE J. Sel. Areas Commun. 39 (2021) 491–499.
[4] A. Jindal, G.S. Aujla, N. Kumar, M. Villari, Guardian: Blockchain-based secure demand response management in smart grid system, IEEE Trans. Serv. Comput. 13 (2020) 613–624.
[5] H. Tyagi, R. Kumar, S.K. Pandey, A detailed study on trust management techniques for security and privacy in IoT: challenges, trends, and research directions, High-Confid. Comput. (2023) 2667–2952.
[6] L. Hirtan, C. Dobre, C. González-Vélez, Blockchain-based reputation for intelligent transportation systems, Eur. Phys. J. B 20 (2020) 791.
[7] P. Zhang, C. Wang, C. Jiang, A. Benslimane, Securityaware virtual network embedding algorithm based on reinforcement learning, IEEE Trans. Netw. Sci. Eng. 8 (2021) 1095–1105.
[8] J. Yu, S. Liu, M. Xu, H. Guo, F. Zhong, W. Cheng, An efficient revocable and searchable MA-ABE scheme with blockchain assistance for C-IoT, IEEE Internet of Things J. 10 (2023) 2754–2766.
[9] J. Yu, B. Yan, H. Qi, S. Wang, W. Cheng, An efficient and secure data sharing scheme for edge-enabled IoT, IEEE Trans. Comput. (2023).
[10] Y. Chen, H. Chen, Y. Zhang, M. Han, M. Siddula, Z. Cai, A survey on blockchain systems: Attacks, defenses, and privacy preservation, High-Confid. Comput. 2 (2022) 2667–2952.
[11] Q. Xie, D.S. Wong, G. Wang, X. Tan, K. Chen, L. Fang, Provably secure dynamic ID-based anonymous twofactor authenticated key exchange protocol with extended security model, IEEE Trans. Inf. Forensics Secur. 12 (2017) 1382–1392.
[12] D. Abbasinezhad-Mood, S.M. Mazinani, M. Nikooghadam, A.O. Sharif, Efficient provably-secure dynamic ID-based authenticated key agreement scheme with enhanced security provision, IEEE Trans. Dependable Secure Comput. 19 (2022) 1227–1238.
[13] Y. Li, Q. Cheng, X. Liu, X. Li, A secure anonymous identity-based scheme in new authentication architecture for mobile edge computing, IEEE Syst. J. 15 (2021) 935–946.
[14] X. Jia, M. Luo, K.-K.R. Choo, L. Li, D. He, A redesigned identity-based anonymous authentication scheme for mobile edge computing, IEEE Internet Things J. 9 (2022) 10108–10120.
[15] S. Shamshad, M.F. Ayub, K. Mahmood, M. Rana, A. Shafiq, J.J. Rodrigues, An identity-based authentication protocol for the telecare medical information system (TMIS) using a physically unclonable function, IEEE Syst. J. 16 (2022) 4831–4838.
[16] A. Braeken, Highly efficient symmetric key based authentication and key agreement protocol using keccak, Sensors 20 (2020) 2160.
[17] B.A. Alzahrani, S.A. Chaudhry, A. Barnawi, W. Xiao, M. Chen, A. Al-Barakati, ILAS-IoT: An improved and lightweight authentication scheme for IoT deployment, J. Ambient Intell. Humaniz. Comput. 13 (2020) 5123–5135.
[18] S. Banerjee, et al., A provably secure and lightweight anonymous user authenticated session key exchange scheme for Internet of Things deployment, IEEE Internet Things J. 6 (2019) 8739–8752.
[19] A. Ghani, K. Mansoor, S. Mehmood, S.A. Chaudhry, A.U. Rahman, M.N. Saqib, Security and key management in IoT-based wireless sensor networks: An authentication protocol using symmetric key, Int. J. Commun. Syst. 32 (2019) e4139.
[20] J. Liu, X. Li, Q. Jiang, M.S. Obaidat, P. Vijayakumar, Bua: A blockchain-based unlinkable authentication in VANETs, in: Proc. IEEE Int. Conf. Commun., ICC, 2020, pp. 1–6.
[21] G. Sang, J. Chen, Y. Liu, H. Wu, Y. Zhou, S. Jiang, PACM: Privacy-preserving authentication scheme with on-chain certificate management for VANETs, IEEE Trans. Netw. Serv. Manag. 20 (2023) 216–228.
[22] Q. Feng, D. He, S. Zeadally, K. Liang, "BPAS: Blockchainassisted privacy-preserving authentication system for vehicular ad hoc networks, IEEE Trans. Ind. Inform. 16 (2020) 4146–4155.
[23] A. Garba, et al., "LightCert4IoTs: Blockchain-based lightweight certificates authentication for IoT applications, IEEE Access. 11 (2023) 28370–28383.
[24] X. Li, T. Jing, R. Li, H. Li, X. Wang, D. Shen, BDRA: Blockchain and decentralized identifiers assisted secure registration and authentication for VANETs, IEEE Internet of Things J. 10 (2023) 12140–12155.
[25] K. Xue, X. Luo, Y. Ma, J. Li, J. Liu, D.S.L. Wei, A distributed authentication scheme based on smart contract for roaming service in mobile vehicular networks, IEEE Trans. Veh. Technol. 71 (2022) 5284–5297.
[26] S. Liu, J. Yu, Y. Xiao, Z. Wan, S. Wang, B. Yan, BC-SABE: Blockchain-aided searchable attribute-based encryption for cloud-IoT, IEEE Internet of Things J. 7 (2020) 7851–7867.
[27] N. Szabo, Smart contracts, 1994, Available: http://szabo.best.vwh.net/smart.contracts.html.
[28] K. Christidis, M. Devetsikiotis, Blockchains and smart contracts for the Internet of Things, IEEE Access. 4 (2016).
[29] G. Indra, R. Taneja, An ECC-time stamp based mutual authen-tication and key management scheme for WSNs, in: Proc. 27th Int. Conf. Adv. Inf. Netw. Appl. Workshops, Barcelona, Spain, 2013, pp. 883–889.
[30] X. Lu, F. Yang, L. Zou, P. Lio, P. Hui, An LTE authentication and key agreement protocol based on the ECC SelfCertified public key, IEEE/ACM Trans. Netw. 31 (2023) 1101–1116.
[31] B.D. Yulianto, L. Budi Handoko, E.H. Pujiono Rachmawanto, M.A. Soeleman, Digital certificate authentication with three-level cryptography (SHA-256, DSA, 3DES), in: 2022 International Seminar on Application for Technology of Information and Communication, iSemantic, Semarang, Indonesia, 2022, pp. 343–350.
[32] Z.L. Xie, L.Y. Jiang, An improved authentication scheme for Internet of Things, in: Proc. IOP Conf. Series Mater. Sci. Eng., Shanghai, China, 2019, p. 12031.
[33] X. Li, J. Peng, F. Wu, M. Khan, C. Chen, "A secure three-factor user authentication protocol with forward secrecy for wireless medical sensor network systems, IEEE Syst. J. 14 (2020) 39–50.
[34] J. Srinivas, A.K. Das, X. Li, M.K. Khan, M. Jo, Designing anonymous signature-based authenticated key exchange scheme for Internet of Things-enabled smart grid systems, IEEE Trans. Ind. Inform. 17 (2021) 4425–4436.
[35] H. Far, M. Bayat, A.K. Das, M.I. Fotouhi, S. Pournaghi, M. Doostari, LAP-TAS: Lightweight anonymous privacypreserving three-factor authentication scheme for WSN-based IIoT, Wirel. Netw. 27 (2021) 1389–1412.
[36] M. Karuppiah others, Secure remote user mutual authentication scheme with key agreement for cloud environment, Mobile Netw. Appl. 24 (2019) 1046–1062.